

Segurança Cibernética em Ambientes IoT/IIoT: Levantamento do Estado da Arte e Lacunas de Pesquisa Relatório Inicial

Matheus Menezes¹, Victoria T. de Paula¹

¹Centro de Informática – Universidade Federal de Pernambuco (CIn/UFPE)
Recife – PE – Brasil

{mhms, email, email, vtps}@cin.ufpe.br

Resumo. *Este relatório apresenta um levantamento inicial do estado da arte em segurança cibernética para ambientes de Internet das Coisas (IoT) e IoT Industrial (IIoT), consolidando a análise de 16 trabalhos publicados entre 2018 e 2026 em fontes como IEEE, ScienceDirect, Springer, arXiv e DOAJ. Os trabalhos foram classificados quanto ao tipo de contribuição (direta ou indireta), à presença de protótipo ou modelo matemático e ao nível de dificuldade técnica, cobrindo subáreas como segurança de camada de rede, autenticação leve, criptografia pós-quântica, detecção de intrusão e blockchain aplicado a IoT. A partir dessa análise, sintetizam-se as principais lacunas de pesquisa identificadas, que servem de base para as próximas etapas do projeto. Propostas de solução e projetos técnicos ainda não são tratados neste documento.*

Abstract. *This report presents an initial survey of the state of the art in cybersecurity for Internet of Things (IoT) and Industrial IoT (IIoT) environments, consolidating the analysis of 16 works published between 2018 and 2026 in venues such as IEEE, ScienceDirect, Springer, arXiv, and DOAJ. The works were classified by type of contribution (direct or indirect), presence of a prototype or mathematical model, and technical difficulty level, covering subareas such as network-layer security, lightweight authentication, post-quantum cryptography, intrusion detection, and blockchain applied to IoT. Based on this analysis, the main research gaps identified are synthesized, providing the basis for the project's next steps. Proposed solutions and technical projects are not yet addressed in this document.*

Palavras-chave: Segurança Cibernética; IoT; IIoT; Detecção de Intrusão; Criptografia Pós-Quântica; Blockchain; Edge-Fog-Cloud.

1. Introdução

O avanço dos sistemas de Internet das Coisas (IoT) e de sua vertente industrial (IIoT) tem sido acompanhado por uma adoção cada vez mais agressiva de técnicas de inteligência artificial, computação de borda (*edge*) e arquiteturas distribuídas ao longo do contínuo *edge-fog-cloud*. Esse crescimento amplia a superfície de ataque dos sistemas e impõe desafios específicos de cibersegurança, frequentemente agravados pelas restrições de hardware, energia e conectividade típicas dos dispositivos IoT.

Este relatório tem como objetivo consolidar o levantamento bibliográfico realizado até o momento sobre segurança cibernética em ambientes IoT/IIoT, organizando os

principais *surveys* e revisões sistemáticas identificados, suas contribuições metodológicas e os problemas em aberto que cada um aponta. Trata-se de uma versão inicial do relatório, restrita à etapa de mapeamento da literatura e à síntese das lacunas de pesquisa; as propostas de solução e os projetos técnicos derivados dessa análise serão detalhados em uma etapa posterior.

2. Metodologia de Levantamento

Foram analisados 16 trabalhos publicados entre 2018 e 2026, abrangendo *surveys* analíticos, revisões sistemáticas – incluindo uma conduzida segundo o protocolo PRISMA 2020 – e estudos com validação experimental. As fontes consultadas incluem periódicos e bases indexadas como IEEE Xplore, IEEE Access, ScienceDirect, Springer, arXiv, DOAJ e RJCSM.

Para cada trabalho, foram registradas seis dimensões de análise: (i) o problema em aberto que motiva o estudo; (ii) as áreas de conhecimento envolvidas; (iii) a existência de protótipo implementado; (iv) a existência de modelo matemático formal; (v) o tipo de proposta de solução, classificada como *direta* – quando o próprio trabalho propõe e valida uma solução técnica original – ou *indireta* – quando o trabalho organiza, categoriza ou compara soluções existentes sem propor um artefato técnico novo; e (vi) o nível de dificuldade técnica do trabalho (iniciante, intermediário ou avançado). Essa classificação permite tanto sumarizar o estado da arte quanto evidenciar, de forma quantitativa, em que pontos a literatura está mais ou menos madura.

3. Trabalhos Relacionados

A Tabela 1 sintetiza as 16 obras analisadas quanto à fonte, ao ano, à existência de protótipo ou modelo matemático, ao tipo de proposta de solução e ao nível de dificuldade técnica. As subseções seguintes detalham o conteúdo de cada trabalho, organizados por subárea temática.

Tabela 1. Síntese comparativa dos trabalhos analisados

Ref.	Fonte	Ano	Protót.	Mod. Mat.	Proposta	Dificuldade
[1]	arXiv	2026	Não	Não	Indireta	Intermediário
[2]	ScienceDirect	2025	Não	Não	Indireta	Intermediário
[3]	RJCSM	2025	Não	Não	Indireta	Intermediário
[4]	DOAJ	2026	Não	Não	Direta	Avançado
[5]	IEEE	2026	Não	Não	Direta	Avançado
[6]	IEEE	2018	Não	Não	Indireta	Iniciante
[7]	IEEE	2023	Não	Não	Indireta	Intermediário
[8]	IEEE	2019	Sim	Não	Direta	Intermediário
[9]	ScienceDirect	2019	Não	Não	Indireta	Iniciante
[10]	–	2020	Não	Sim	Indireta	Intermediário
[11]	IEEE	2020	Não	Não	Indireta	Iniciante
[12]	IEEE Access	2021	Não	Não	Indireta	Intermediário
[13]	IEEE Access	2020	Não	Não	Indireta	Intermediário
[14]	Springer	2021	Não	Não	Indireta	Iniciante
[15]	Springer	2019	Não	Não	Indireta	Iniciante
[16]	IEEE/Springer	2024	Sim	Sim	Direta	Avançado

3.1. Visões Gerais de Segurança em Redes IoT

Três dos trabalhos analisados oferecem panoramas gerais sobre segurança em redes IoT, servindo de ponto de partida conceitual para as demais subáreas. Gurunath et al. [6] discutem a ausência de uma análise sistemática e integrada das vulnerabilidades de dispositivos IoT com recursos limitados, categorizando doze tipos de ataques segundo seu impacto (baixo, médio, alto e altíssimo) e descrevendo contramedidas conceituais como *firewalls*, segmentação de rede e sistemas de detecção de intrusão; por se tratar de uma revisão essencialmente descritiva, sem proposta de protótipo ou modelo formal, o trabalho é classificado como de nível iniciante.

Noor e Hassan [9] revisam, via Web of Knowledge, as tendências de pesquisa em segurança IoT entre 2016 e 2018, categorizando os mecanismos de segurança por camada (percepção, rede e aplicação) e constatando que autenticação responde por cerca de 60% dos trabalhos analisados, ao passo que criptografia leve e gerenciamento de confiança aparecem como tendências emergentes e ainda pouco consolidadas. Já o *survey* contemporâneo sobre tecnologias, aplicações e desafios de IoT [15] aponta a fragmentação das soluções *end-to-end* e a escassez de ferramentas voltadas a cenários críticos de saúde, analisando publicações de 2013 a 2018 via Scopus para identificar tendências em dispositivos médicos (como sistemas *Organ-on-Chip*) e protocolos leves de comunicação.

3.2. Segurança na Camada de Rede e Controle de Acesso

Na camada de rede, Jahangeer et al. [7] concentram-se na ausência de mecanismos padronizados e distribuídos de segurança para o protocolo RPL em redes de baixa potência (6LoWPAN), revisando sistematicamente 83 referências de periódicos Q1 e conferências *tier-1* publicadas entre 2015 e 2022. Os autores mapeiam ataques internos como *sinkhole*, *blackhole*, *sybil*, *wormhole*, clonagem de identidade e *selective forwarding*, e comparam o desempenho de abordagens de aprendizado de máquina (SVM, KNN, DNN e Random Forest) na detecção desses ataques, considerando métricas como consumo de energia, escalabilidade, taxa de entrega de pacotes (PDR) e vazão.

Em direção complementar, o *survey* sobre modelos de controle de acesso em computação de borda [2] parte da dificuldade de conciliar escalabilidade, flexibilidade, baixa latência e economia de recursos em ambientes de borda heterogêneos. Sua contribuição está na proposta de uma taxonomia original que organiza as soluções existentes segundo o ciclo de vida do dado – coleta, armazenamento e uso –, incluindo uma análise específica do papel do *blockchain* nesse contexto; ainda assim, o trabalho não chega a propor um novo modelo de controle de acesso, permanecendo no campo da sistematização indireta da literatura.

3.3. Autenticação e Criptografia (Leve e Pós-Quântica)

A escassez de protocolos de autenticação leve capazes de atender simultaneamente às restrições de hardware e energia dos dispositivos IoT e de resistir a ataques modernos é o problema central tratado em [3], que compara protocolos baseados em *blockchain* e em aprendizado de máquina segundo critérios de desempenho, segurança e adequação a dispositivos restritos, sem, no entanto, propor um protocolo inédito.

Já a revisão sistemática sobre criptografia pós-quântica (PQC) em IoT [4] representa um dos poucos trabalhos do levantamento com proposta direta de solução: a partir

de um funil que parte de 5.151 publicações e seleciona 161 estudos relevantes – seguindo o protocolo PRISMA 2020 –, os autores categorizam algoritmos PQC e seus desafios de implementação em dispositivos com restrições severas de energia e processamento, propondo um *framework* conceitual de contramedidas e ilustrando sua adoção em um estudo de caso hipotético, além de apontar direções futuras concretas para a integração viável de PQC em IoT.

3.4. Aprendizado de Máquina e Detecção de Intrusão

Dois trabalhos relacionados a detecção de intrusão se destacam pelo nível de validação técnica. Roopak, Tian e Chambers [8] implementam e comparam quatro modelos de aprendizado profundo (MLP, CNN unidimensional, LSTM e um modelo híbrido CNN+LSTM) para detecção de ataques DDoS, utilizando o *dataset* CICIDS2017 balanceado por duplicação e treinado em Keras/TensorFlow sobre hardware Intel Core-i7 com 16 GB de RAM; o modelo híbrido atinge 97,16% de acurácia e 99,1% de *recall*, superando SVM, Naive Bayes e Random Forest, e os autores propõem uma arquitetura *fog-to-node* distribuída como direção futura – ainda não implementada – para reduzir os gargalos de escalabilidade do processamento centralizado em nuvem.

Em um nível de complexidade mais avançado, o *survey* sobre aprendizado federado seguro e explicável para detecção de intrusão em IoT [5] parte da ausência de sistemas de IDS federados que sejam, ao mesmo tempo, seguros contra envenenamento e vazamento de dados, explicáveis (XAI) e reproduzíveis sob restrições operacionais reais. Como contribuição direta, os autores propõem uma arquitetura de referência e um *checklist* de padronização que unifica privacidade, explicabilidade e robustez adversarial sob uma lente centrada em artefatos (dados, atualizações de modelo e explicações), mapeando lacunas da literatura em forma de contribuições testáveis.

3.5. Inteligência Artificial no Contínuo Edge-Fog-Cloud

A adoção agressiva de inteligência artificial ao longo do contínuo *edge-fog-cloud* em ambientes industriais é o foco de [1], que investiga a ausência de uma análise sistemática dos efeitos colaterais de segurança e do *trade-off* entre desempenho e proteção nesse contexto. O trabalho distingue vulnerabilidades em nível de software – decorrentes de IA tradicional e generativa – das vulnerabilidades de infraestrutura associadas à própria arquitetura IIoT, investigando ameaças e efeitos colaterais específicos de cada camada, ainda que sem propor uma solução técnica fechada.

No outro extremo do espectro de validação, o trabalho sobre segurança de frotas de drones em arquiteturas de borda habilitadas por 6G [16] é o único do levantamento a apresentar tanto protótipo quanto modelo matemático. Motivado pela alta latência e baixa acurácia de detecção dos sistemas atuais para logística de saúde crítica, propõe a arquitetura CNN-SS e um modelo híbrido CNN-LSTM para detecção de intrusão em tempo real e agendamento seguro de tarefas, validando a proposta por simulação e demonstrando latência ultra-baixa, da ordem de 8 ms.

3.6. Blockchain Aplicado a Redes e Dispositivos IoT

Quatro trabalhos do levantamento tratam da aplicação de *blockchain* a diferentes camadas de redes IoT. O *survey* sobre arquitetura, consenso e modelagem de tráfego em sistemas

IoT-*blockchain* [10] é o único, além do trabalho sobre drones, a apresentar um modelo matemático: parte da falta de padronização nas arquiteturas IoT-*blockchain* e dos gargalos de desempenho em mecanismos de consenso para dispositivos restritos, propondo uma taxonomia original de cinco camadas e analisando matematicamente modelos de tráfego P2P e distribuições de recursos, além de comparar protocolos de consenso como PBFT, Ripple e *Proof-of-Burn* em arquiteturas como Smart Home, LO3 Energy e Slock.it.

De forma mais abrangente, o *survey* sobre sistemas e aplicações baseados em *blockchain* [11] discute a ineficiência e a falta de confiança em sistemas de rastreabilidade centralizados, classificando as aplicações em três estágios evolutivos e sugerindo o uso de contratos inteligentes para coordenar ativos e combater fraudes comerciais, com foco em rastreabilidade antifalsificação e proteção de dados médicos.

Já o levantamento sobre *blockchain* e veículos autônomos [12] aborda a lacuna de segurança de dados de sensores e de responsabilidade jurídica em acidentes envolvendo veículos autônomos sob alta mobilidade; a partir da análise comparativa de mais de cem artigos, o trabalho oferece um *roadmap* estratégico e identifica oito conceitos fundamentais para a integração entre as duas tecnologias, sem, contudo, propor um artefato técnico novo. Por fim, o *survey* sobre a implantação de *blockchain* em redes definidas por software (SDN) [13] parte da vulnerabilidade do controlador centralizado da SDN a ataques de saturação (DDoS), demonstrando, por meio de uma análise crítica de questões de pesquisa, como a descentralização promovida pelo *blockchain* pode distribuir funcionalidades de rede e validar regras de fluxo automaticamente, mitigando pontos únicos de falha.

3.7. Dados em Larga Escala em Ambientes IoT

Por fim, o *survey* temático sobre análise de grandes volumes de dados (*big data*) em IoT [14] trata da complexidade de extrair valor real a partir da massa de dados heterogêneos gerados por bilhões de dispositivos conectados. O trabalho categoriza os mecanismos analíticos em quatro níveis – descritivo, diagnóstico, preditivo e prescritivo – e compara ferramentas de processamento como Spark e MapReduce no contexto IoT, oferecendo um direcionamento conceitual para o desenvolvimento de *frameworks* de análise, sem aprofundar os aspectos de segurança propriamente ditos.

4. Lacunas de Pesquisa Identificadas

Tomados individualmente, os 16 trabalhos deixam parcialmente abertos os problemas que motivam suas próprias investigações: a integração viável de PQC em dispositivos restritos [4], a defesa distribuída contra ataques internos ao RPL [7], a reprodutibilidade de IDS federados sob restrições operacionais reais [5], a padronização de arquiteturas IoT-*blockchain* [10] e a responsabilidade jurídica em acidentes com veículos autônomos [12] permanecem, em maior ou menor grau, como direções de pesquisa em aberto em suas respectivas subáreas. Mais relevante para a definição dos próximos passos deste projeto, contudo, são as lacunas que emergem da análise conjunta do conjunto de trabalhos, discutidas a seguir.

4.1. Lacunas Transversais ao Conjunto da Literatura

O primeiro padrão observado é a predominância de contribuições indiretas sobre contribuições diretas: do total de 16 trabalhos, 12 (75%) limitam-se a organizar, comparar ou

categorizar conhecimento já existente, enquanto apenas 4 (25%) propõem e validam uma solução técnica original [4, 5, 8, 16]. Esse padrão se reflete também no nível de validação empírica ou formal: apenas 3 dos 16 trabalhos (menos de 20%) apresentam protótipo implementado ou modelo matemático, e somente um deles – o estudo sobre segurança de drones em arquiteturas 6G [16] – reúne as duas formas de validação simultaneamente. Isso sugere que a literatura sobre segurança em IoT/IIoT está, em sua maior parte, em estágio de mapeamento e diagnóstico, havendo espaço considerável para trabalhos que traduzam as taxonomias e os riscos já identificados em artefatos técnicos testáveis e reprodutíveis.

Um segundo padrão é a fragmentação entre as linhas de pesquisa voltadas à criptografia e à autenticação [3, 4] e as linhas voltadas à detecção de intrusão baseada em aprendizado de máquina [5, 7, 8]: nenhum dos trabalhos analisados integra, em um único *framework*, garantias criptográficas leves ou pós-quânticas com mecanismos adaptativos de detecção, tratando essas frentes como problemas independentes mesmo quando aplicados ao mesmo tipo de dispositivo restrito.

Embora [1] aponte explicitamente a ausência de um modelo de ameaças unificado para o contínuo *edge-fog-cloud* que incorpore os riscos da IA generativa, os demais trabalhos relacionados a esse contínuo [2, 16] tratam apenas de aspectos pontuais – controle de acesso e agendamento seguro de tarefas, respectivamente –, sem compor uma visão integrada das camadas de software e infraestrutura. Essa lacuna é particularmente relevante para sistemas com forte dependência de inferência distribuída, como veículos autônomos e frotas de drones.

Diversos ataques discutidos no levantamento dependem, por construção, de mascarar tráfego ou comportamento malicioso como legítimo – caso dos ataques *sinkhole* e *selective forwarding* no protocolo RPL [7] e do tráfego adversarial que poderia evadir os classificadores de DDoS avaliados em [8]. Nenhum dos 16 trabalhos, contudo, propõe ou utiliza um *benchmark* padronizado para avaliar a robustez de mecanismos de detecção especificamente contra esse tipo de ataque mimético ou evasivo, o que configura uma lacuna metodológica relevante para a validação de futuras soluções de IDS.

De modo semelhante, o gerenciamento de confiança é citado em [9] apenas como mecanismo emergente e complementar à autenticação, sem que nenhum dos trabalhos analisados proponha ou valide um esquema de pontuação de confiança dinâmico e sensível ao contexto – capaz de se adaptar ao histórico de comportamento do dispositivo e às condições de rede – compatível com as restrições de recursos típicas de IoT. Essa imaturidade contrasta com o estágio relativamente mais avançado das áreas de autenticação e criptografia leve.

Por fim, em domínios de aplicação crítica, como veículos autônomos [12] e logística de saúde baseada em drones [16], questões de responsabilidade jurídica e de governança de dados de sensores em cenários de falha ou acidente são apontadas como relevantes, mas não chegam a ser tecnicamente endereçadas por nenhum dos trabalhos – permanecendo como um problema essencialmente normativo e interdisciplinar, ainda sem tratamento técnico consolidado na literatura de segurança revisada.

5. Aprofundamento das Lacunas Prioritárias e Propostas de Investigação

5.1. Mapeamento Consolidado de Problemas em Aberto

Complementando o levantamento bibliográfico apresentado nas seções anteriores, a equipe consolidou um mapeamento mais granular dos problemas em aberto recorrentes na literatura, organizado em duas frentes complementares. A primeira frente concentra-se em lacunas críticas de natureza regulatória e de segurança da própria inteligência artificial: a responsabilidade jurídica em acidentes envolvendo veículos autônomos monitorados por *blockchain*, em que o registro imutável fornece evidência pericial, mas o quadro regulatório ainda não define se a culpa recai sobre fabricante, desenvolvedor ou proprietário (Jain et al.); a inviabilidade de migrar dispositivos legados para criptografia pós-quântica diante do risco de ataques do tipo *harvest now, decrypt later* (Adere et al.); a vulnerabilidade dos próprios mecanismos de explicabilidade (XAI) a ataques de *fooling*, que permitem a um adversário forjar explicações enquanto mantém um comportamento malicioso (Bilal et al.; estudo *Downsides of Smartness* [1]); e a ausência de conformidade regulatória global que padronize o compartilhamento de dados entre fabricantes e autoridades (Jain et al.; Zhang et al.).

A segunda frente, voltada a problemas mais diretamente técnicos, abrange o conflito entre segurança robusta e restrição de recursos – citado por Adere et al. e por Waghmode et al. no contexto de comunicação V2X –; a vulnerabilidade a ataques de negação de serviço (DDoS), em especial em redes definidas por software cujo controlador centralizado constitui um ponto único de falha (Roopak et al. [8]; Alharbi [13]); a fragmentação decorrente da diversidade de protocolos como MQTT e CoAP, que dificulta a validação de confiança mútua entre dispositivos heterogêneos (Balaji et al.; Lao et al.); os efeitos colaterais imprevistos da adoção agressiva de IA, como envenenamento de dados e decisões de caixa-preta tomadas em milissegundos (estudo *Downsides of Smartness* [1]); e as lacunas em autenticação e gestão de confiança em redes P2P massivas, em que o uso de *smart contracts* para pontuação de reputação ainda enfrenta problemas de escalabilidade (Waghmode et al.).

A partir desse mapeamento mais amplo, cinco lacunas foram selecionadas para aprofundamento e desenho experimental, priorizadas por seu potencial de implementação e avaliação em ambiente acadêmico, com uso de simulação, *datasets* públicos ou hardware de baixo custo.

5.2. Lacuna A – Trade-off entre Latência Crítica e Segurança Blockchain/PQC

Problema técnico. Integrar mecanismos criptográficos robustos – consenso *blockchain*, assinaturas pós-quânticas – em comunicações que exigem resposta em sub-milissegundos, como a frenagem de emergência em comunicação veículo-a-veículo (V2V), sem violar o orçamento de latência do sistema de controle físico.

Por que não foi resolvido. Protocolos de consenso, mesmo os mais leves como o PBFT, exigem múltiplas rodadas de comunicação entre nós, e chaves e assinaturas PQC são maiores e mais custosas computacionalmente que os esquemas ECC/RSA atuais. A literatura tende a tratar segurança e tempo real como otimizações independentes, sem um modelo conjunto de latência-segurança.

Evidências. Adere et al.; Waghmode et al.

Pergunta de pesquisa. Qual é o impacto em latência ponta-a-ponta de assinaturas PQC leves – baseadas em *hash*, como o SPHINCS+ – combinadas a um esquema de validação assíncrona em mensagens críticas de frenagem de emergência V2V, e esse impacto é compatível com um orçamento de latência inferior a 10 ms?

Hipótese testável. Um esquema de validação otimista – em que a ação física ocorre antes da confirmação criptográfica completa, validada posteriormente em segundo plano – mantém a latência de mensagens críticas abaixo de 10 ms sem reduzir significativamente a integridade da mensagem, em comparação a um esquema síncrono tradicional.

Metodologia experimental. Simular uma rede V2V em um simulador de redes (por exemplo, ns-3), integrando uma biblioteca de referência para PQC (liboqs, com Kyber/Dilithium/SPHINCS+); implementar os dois esquemas – síncrono e otimista – e medir latência, taxa de perda de mensagens e *overhead* de banda sob diferentes cargas de tráfego simulado, comparando ambos a um *baseline* sem criptografia.

Viabilidade: Média. As ferramentas e bibliotecas necessárias são públicas, mas a integração entre o simulador de rede e o modelo de tráfego veicular demanda esforço de engenharia experimental não trivial.

5.3. Lacuna B – Falta de Validação de Explicabilidade (XAI) em Ambientes Adversariais

Problema técnico. Ausência de métricas que validem se as explicações geradas por sistemas de IDS baseados em IA (SHAP, LIME) são fiéis ao raciocínio real do modelo e resistentes a manipulação adversarial – um atacante pode preservar a predição correta do classificador enquanto força a explicação a apontar para uma causa incorreta.

Por que não foi resolvido. O XAI é tradicionalmente tratado como uma camada de visualização posterior à predição, desacoplada da avaliação de segurança do sistema; não há, na literatura revisada, um *benchmark* padronizado e amplamente adotado de robustez de explicação – a maioria dos trabalhos mede apenas a acurácia da predição.

Evidências. Bilal et al.; estudo *Downsides of Smartness* [1].

Pergunta de pesquisa. É possível, com perturbações adversariais imperceptíveis, manter a predição correta de um classificador de IDS enquanto se altera substancialmente o *ranking* de *features* apontado por SHAP ou LIME – e qual métrica de estabilidade detecta essa manipulação?

Hipótese testável. Existe uma perturbação adversarial que preserva o rótulo predito por um classificador treinado em um *dataset* público de IDS, mas altera significativamente o *ranking* de *features* do SHAP, sendo essa manipulação detectável por uma queda na correlação de Spearman entre os *rankings* de explicação antes e depois do ataque.

Metodologia experimental. Treinar um classificador (Random Forest ou MLP) em um *dataset* público de detecção de intrusão (CICIDS2017 ou NSL-KDD); gerar explicações de referência via SHAP; aplicar um ataque de *fooling* por otimização, que minimize a distância para uma explicação-alvo sujeito à restrição de manter a predição original; medir a taxa de sucesso do ataque e a queda na correlação de *ranking* antes e depois da manipulação.

Viabilidade: Alta. *Datasets*, bibliotecas de XAI e implementações de referên-

cia de ataques adversariais já estão publicamente disponíveis, tornando o experimento totalmente reproduzível sem necessidade de hardware especializado.

5.4. Lacuna C – Inviabilidade de PQC em Dispositivos IoT de Baixo Custo (Legados)

Problema técnico. Os algoritmos de criptografia pós-quântica padronizados pelo NIST (Kyber, Dilithium) exigem memória e capacidade de processamento – em especial para aritmética de reticulados (*lattices*) – que excedem em ordens de grandeza a capacidade de microcontroladores simples, tipicamente entre 10 KB e 100 KB de memória.

Por que não foi resolvido. O processo de padronização do NIST priorizou hardware de propósito geral, sem considerar explicitamente dispositivos embarcados de baixíssimo custo; não há aceleração nativa de hardware para aritmética de reticulados nesses chips, o que torna a implementação em software lenta e intensiva em memória.

Evidências. Adere et al.; Lao et al.

Pergunta de pesquisa. Qual é o *footprint* mínimo de memória e o *overhead* de execução para implementar uma versão reduzida ou híbrida de um algoritmo PQC do NIST em um microcontrolador com cerca de 32 KB de RAM, e o quão distante esse resultado está do limite viável para autenticação leve em dispositivos legados?

Hipótese testável. Um esquema híbrido – em que a PQC é utilizada apenas na fase inicial de *handshake*, com criptografia simétrica para o restante da sessão – reduz o uso de RAM em pelo menos 40% em comparação a uma implementação PQC completa, mantendo viabilidade em microcontroladores na faixa de 32 a 64 KB.

Metodologia experimental. Utilizar hardware real de baixo custo (ESP32 ou STM32) com bibliotecas PQC portadas para sistemas embarcados (liboqs/pqm4 ou wolfSSL); medir uso de memória, tempo de execução e consumo de energia para um *handshake* simulado em três configurações – PQC completo, PQC híbrido e PQC reduzido –, comparando os resultados a um *baseline* em ECC.

Viabilidade: Alta. As placas de hardware e as bibliotecas necessárias são públicas e de baixo custo; as medições de *footprint* de memória e energia são totalmente factíveis em ambiente acadêmico.

5.5. Lacuna D – Adaptação ao *Concept Drift* em Aprendizado Federado (FL) para IDS

Problema técnico. Modelos de detecção de intrusão treinados via aprendizado federado perdem acurácia de forma acelerada quando o perfil do tráfego se altera (*drift*) – por exemplo, com o surgimento de novos padrões de ataque –, e não há mecanismo estabelecido para atualizar simultaneamente o modelo e as explicações de XAI de forma estável entre rodadas de treinamento.

Por que não foi resolvido. A maior parte dos trabalhos revisados utiliza *datasets* estáticos, ignorando a natureza temporal e evolutiva dos ataques reais; o re-treinamento federado introduz risco de esquecimento catastrófico e de instabilidade nas explicações geradas, sem que existam métricas estabelecidas para medir esse efeito.

Evidências. Bilal et al.

Pergunta de pesquisa. Qual é a taxa de degradação de acurácia de um IDS federado sob *concept drift* simulado, e um esquema de re-treinamento incremental federado é capaz de recuperar essa acurácia sem comprometer a estabilidade das explicações entre rodadas?

Hipótese testável. Um re-treinamento incremental com janela deslizante, combinado a uma técnica de regularização contra esquecimento catastrófico (como *Elastic Weight Consolidation*), recupera ao menos 90% da acurácia original após um *drift* simulado, mantendo a variação da explicação SHAP entre rodadas abaixo de um limiar pré-definido.

Metodologia experimental. Utilizar um *dataset* de IDS particionado cronologicamente, ou um *drift* sintético injetado artificialmente; simular aprendizado federado com múltiplos clientes (por exemplo, com Flower ou TensorFlow Federated), introduzindo gradualmente um novo padrão de ataque em parte dos clientes; medir a curva de acurácia e a estabilidade das explicações SHAP ao longo das rodadas, comparando-as a um *baseline* sem mecanismo de adaptação.

Viabilidade: Média. Os *frameworks* e *datasets* necessários são acessíveis, mas o desenho de um cenário de *drift* realista e a medição de estabilidade de explicações exigem maior esforço de engenharia experimental.

5.6. Lacuna E – Responsabilidade Jurídica e Atribuição de Falhas

Problema técnico. Traduzir evidências imutáveis registradas em *blockchain* – *logs* de sensores, decisões de percepção e planejamento da IA – em atribuição clara de responsabilidade legal em acidentes envolvendo veículos autônomos, dado que os marcos regulatórios atuais não incorporam o conceito de “agência de máquina” nem padronizam como esses registros devem ser interpretados pericialmente.

Por que não foi resolvido. Trata-se, em sua essência, de um problema jurídico-regulatório, e não estritamente de engenharia: a tecnologia de evidência (registro imutável em *blockchain*) já existe e é tecnicamente madura, mas falta a “ponte” formal entre o registro técnico e o processo legal de atribuição de culpa.

Evidências. Jain et al. [12].

Pergunta de pesquisa (com escopo técnico viável). Um formato padronizado de registro técnico-legal – que correlacione e assine digitalmente decisões de percepção, planejamento e atuação – é suficiente para que avaliadores humanos atribuam responsabilidade de forma mais consistente entre si, em comparação a um registro não estruturado, a partir de cenários de acidente descritos textualmente?

Hipótese testável. Cenários de incidente apresentados em um formato de registro estruturado geram maior concordância entre avaliadores – medida pelo coeficiente Kappa de Cohen – do que os mesmos cenários apresentados em formato de registro não estruturado.

Metodologia experimental. Construir um conjunto de cenários hipotéticos de incidente (falha de sensor, erro de planejamento do sistema, intervenção tardia do operador humano), descritos como *logs* sintéticos estruturados – sem necessidade de um simulador de condução –, contrastando esse formato padronizado com uma versão não estruturada

dos mesmos cenários; apresentar ambas as versões a um pequeno painel de avaliadores e medir a concordância entre eles na atribuição de responsabilidade.

Viabilidade: Baixa. A montagem dos cenários e a coleta de avaliações é tecnicamente factível, mas o que se mede é a clareza e a concordância perceptual entre avaliadores, e não a resolução real da lacuna jurídica – que depende de mudança regulatória e está fora do alcance de um experimento acadêmico de simulação. Recomenda-se manter esta lacuna no relatório como discussão relevante, sem tratá-la como projeto técnico prioritário.

5.7. Síntese e Priorização

Considerando a viabilidade de implementação em ambiente acadêmico, as lacunas B (validação de XAI em ambientes adversariais) e C (PQC leve em hardware real) apresentam a maior viabilidade: utilizam ferramentas, *datasets* e hardware de baixo custo já publicamente disponíveis, com resultados mensuráveis sem ambiguidade metodológica. As lacunas A (*trade-off* latência-segurança) e D (*concept drift* em FL) apresentam viabilidade média, exigindo maior esforço de integração entre ferramentas de simulação e *frameworks* de aprendizado federado. Já a lacuna E (responsabilidade jurídica) é mantida no relatório por sua relevância para a aceitação social e regulatória das tecnologias discutidas, mas sua natureza predominantemente normativa limita sua viabilidade como projeto técnico de avaliação experimental.

6. Considerações Finais

Este relatório consolidou o levantamento inicial de 16 trabalhos sobre segurança cibernética em ambientes IoT/IIoT, organizando-os por subárea temática e classificando-os quanto ao tipo de contribuição, ao nível de validação técnica e à complexidade. A análise evidenciou uma literatura majoritariamente analítica e taxonômica, com poucos trabalhos apresentando validação experimental ou formalização matemática, e revelou lacunas tanto específicas de cada subárea quanto transversais ao conjunto da literatura – em especial relacionadas à integração entre criptografia e detecção adaptativa, à modelagem unificada de ameaças no contínuo *edge-fog-cloud* e à maturidade de mecanismos de confiança dinâmica e de *benchmarks* para ataques miméticos.

Em complemento, foram aprofundadas cinco lacunas prioritárias, cada uma associada a uma pergunta de pesquisa, uma hipótese testável e um desenho experimental específico, das quais a validação adversarial de explicabilidade (XAI) e a viabilidade de PQC leve em hardware restrito apresentam a maior viabilidade de implementação em ambiente acadêmico. As próximas etapas deste trabalho envolverão a seleção definitiva do projeto a ser implementado entre as alternativas de maior viabilidade e o detalhamento do desenho experimental escolhido.

A. Síntese Consolidada das Lacunas de Pesquisa

A Tabela 2 apresenta uma visão unificada das cinco lacunas priorizadas, reunindo em um único lugar os sete critérios de análise adotados: problema técnico, causa da não-resolução, evidências da literatura, pergunta de pesquisa derivada, hipótese testável, metodologia experimental proposta e avaliação de viabilidade. A tabela complementa o detalhamento em prosa das seções anteriores e serve como referência rápida para a tomada de decisão sobre o projeto a ser conduzido nas etapas seguintes.

Tabela 2. Síntese das cinco lacunas de pesquisa prioritizadas

Lacuna	Problema Técnico	Por que não resolvido	Evidências	Pergunta de Pesquisa	Hipótese Testável	Metodologia Experimental	Viab.
A – Trade-off Latência/Segurança	Mecanismos como blockchain e PQC introduzem latência superior a 10 ms em comunicações V2V críticas (ex.: frenagem de emergência).	Consenso PBFT exige múltiplas rodadas de comunicação; assinaturas PQC são maiores e mais custosas que ECC/RSA; literatura trata segurança e tempo real como otimizações independentes.	Adere et al.; Waghmode et al.	Assinaturas baseadas em <i>hash</i> (SPHINCS+) com validação assíncrona são compatíveis com latência <10 ms em comunicações V2V de frenagem de emergência?	Um esquema de validação otimista — ação física antes da confirmação criptográfica completa — mantém latência <10 ms sem degradar integridade da mensagem.	Simular rede V2V em ns-3 integrando liboqs (Kyber/SPHINCS+); comparar esquemas síncrono vs. otimista vs. <i>baseline</i> sem criptografia; medir latência, perda de pacotes e <i>overhead</i> de banda.	Média
B – XAI em Ambientes Adversariais	Explicações de sistemas IDS baseados em IA (SHAP, LIME) podem ser manipuladas para apontar causa incorreta enquanto a predição do classificador permanece correta.	XAI é tratado como visualização pós-hoc desacoplada da avaliação de segurança; sem <i>benchmark</i> padronizado de robustez de explicação na literatura revisada.	Bilal et al.; [1]	É possível, com perturbações adversariais imperceptíveis, preservar a predição correta de um classificador IDS enquanto se altera substancialmente o <i>ranking</i> de <i>features</i> do SHAP?	Ataque de <i>fooling</i> altera significativamente o <i>ranking</i> SHAP, sendo detectável por queda na correlação de Spearman entre <i>rankings</i> antes e depois do ataque.	Treinar RF/MLP em CICIDS2017 ou NSL-KDD; gerar explicações SHAP de referência; aplicar ataque de <i>fooling</i> por otimização; medir taxa de sucesso e correlação de <i>ranking</i> .	Alta
C – PQC em IoT de Baixo Custo (Legados)	Algoritmos NIST-PQC (Kyber, Dilithium) exigem RAM e poder de processamento ordens de grandeza além da capacidade de microcontroladores (10–100 KB).	Padronização NIST priorizou hardware geral, negligenciando dispositivos embarcados de baixíssimo custo; sem aceleração nativa para aritmética de <i>lattices</i> nesses chips.	Adere et al.; Lao et al.	Um esquema PQC híbrido — PQC no <i>handshake</i> + simétrico no restante — reduz uso de RAM $\geq 40\%$ em relação ao PQC completo, mantendo viabilidade em microcontroladores de 32–64 KB?	PQC apenas no <i>handshake</i> com criptografia simétrica para o restante da sessão reduz RAM $\geq 40\%$ vs. PQC completo.	Implementar PQC completo/híbrido/reduzido em ESP32 ou STM32 com liboqs/pqm4; medir RAM, tempo de execução e consumo de energia vs. <i>baseline</i> ECC.	Alta
D – Concept Drift em FL-IDS	Modelos FL-IDS perdem acurácia com mudanças no perfil de tráfego (<i>drift</i>), sem mecanismo para atualizar modelo e explicações XAI de forma estável entre rodadas.	Literatura emprega <i>datasets</i> estáticos, ignorando a natureza temporal dos ataques reais; re-treinamento federado causa esquecimento catastrófico e instabilidade de explicações sem métricas consolidadas.	Bilal et al.	Re-treinamento incremental com <i>Elastic Weight Consolidation</i> (EWC) recupera $\geq 90\%$ da acurácia pós- <i>drift</i> sem comprometer a estabilidade das explicações SHAP entre <i>rounds</i> ?	Janela deslizante + EWC recupera $\geq 90\%$ da acurácia após <i>drift</i> simulado, mantendo variação SHAP entre <i>rounds</i> abaixo de limiar pré-definido.	Particionar dataset IDS cronologicamente; simular FL com Flower; injetar gradualmente novo padrão de ataque em parte dos clientes; medir curva de acurácia e estabilidade SHAP por <i>round</i> .	Média
E – Responsabilidade Jurídica e Atribuição de Falhas	Registros imutáveis em <i>blockchain</i> (logs de decisões de IA) não se traduzem diretamente em atribuição legal de culpa; marcos regulatórios não reconhecem “agência de máquina”.	Problema predominantemente jurídico-regulatório: evidência técnica já existe e é madura, mas falta <i>bridge</i> formal entre registro técnico e quadro legal vigente.	Jain et al. [12]	Um formato padronizado de <i>log</i> técnico-legal gera maior concordância entre avaliadores na atribuição de responsabilidade em acidentes hipotéticos vs. <i>log</i> não estruturado?	<i>Logs</i> estruturados produzem coeficiente Kappa de Cohen superior ao de <i>logs</i> não estruturados aplicados aos mesmos cenários de incidente hipotético.	Construir cenários de incidente com <i>logs</i> sintéticos estruturados vs. não estruturados; apresentar a painel de avaliadores; medir concordância via Kappa de Cohen.	Baixa

Referências

- [1] Downsides of Smartness Across Edge-Cloud Continuum in Modern Industry. arXiv, 2026.
- [2] Edge Computing for IoT: Novel Insights from a Comparative Analysis of Access Control Models. ScienceDirect, 2025.
- [3] Lightweight Authentication for Devices in IoT Environment: A Survey. RJCSM, 2025.
- [4] ADERE et al. Systematic Review on Securing IoT Systems with Post-Quantum Cryptography. DOAJ, 2026.
- [5] BILAL et al. Secure and Explainable Federated Learning for IoT Intrusion Detection: A Comprehensive Survey. IEEE, 2026.
- [6] GURUNATH et al. An Overview: Security Issue in IoT Network. IEEE, 2018.
- [7] JAHANGEER et al. A Review on the Security of IoT Networks: From Network Layer's Perspective. IEEE, 2023.
- [8] ROOPAK; TIAN; CHAMBERS. Deep Learning Models for Cyber Security in IoT Networks. IEEE, 2019.
- [9] NOOR; HASSAN. Current Research on Internet of Things (IoT) Security: A Survey. ScienceDirect, 2019.
- [10] A Survey of IoT Applications in Blockchain Systems: Architecture, Consensus, and Traffic Modeling, 2020.
- [11] Blockchain-based Systems and Applications: A Survey. IEEE, 2020.
- [12] JAIN et al. Blockchain and Autonomous Vehicles: Recent Advances and Future Directions. IEEE Access, 2021.
- [13] ALHARBI. Deployment of Blockchain Technology in Software Defined Networks: A Survey. IEEE Access, 2020.
- [14] Survey on IoT-based Big Data Analytics. Springer, 2021.
- [15] IoT Technology, Applications and Challenges: A Contemporary Survey. Springer, 2019.
- [16] Next-Generation Deep Learning Integrated Drone Security: A 6G-Powered Enabled Edge Cloud Architecture. IEEE/Springer, 2024.